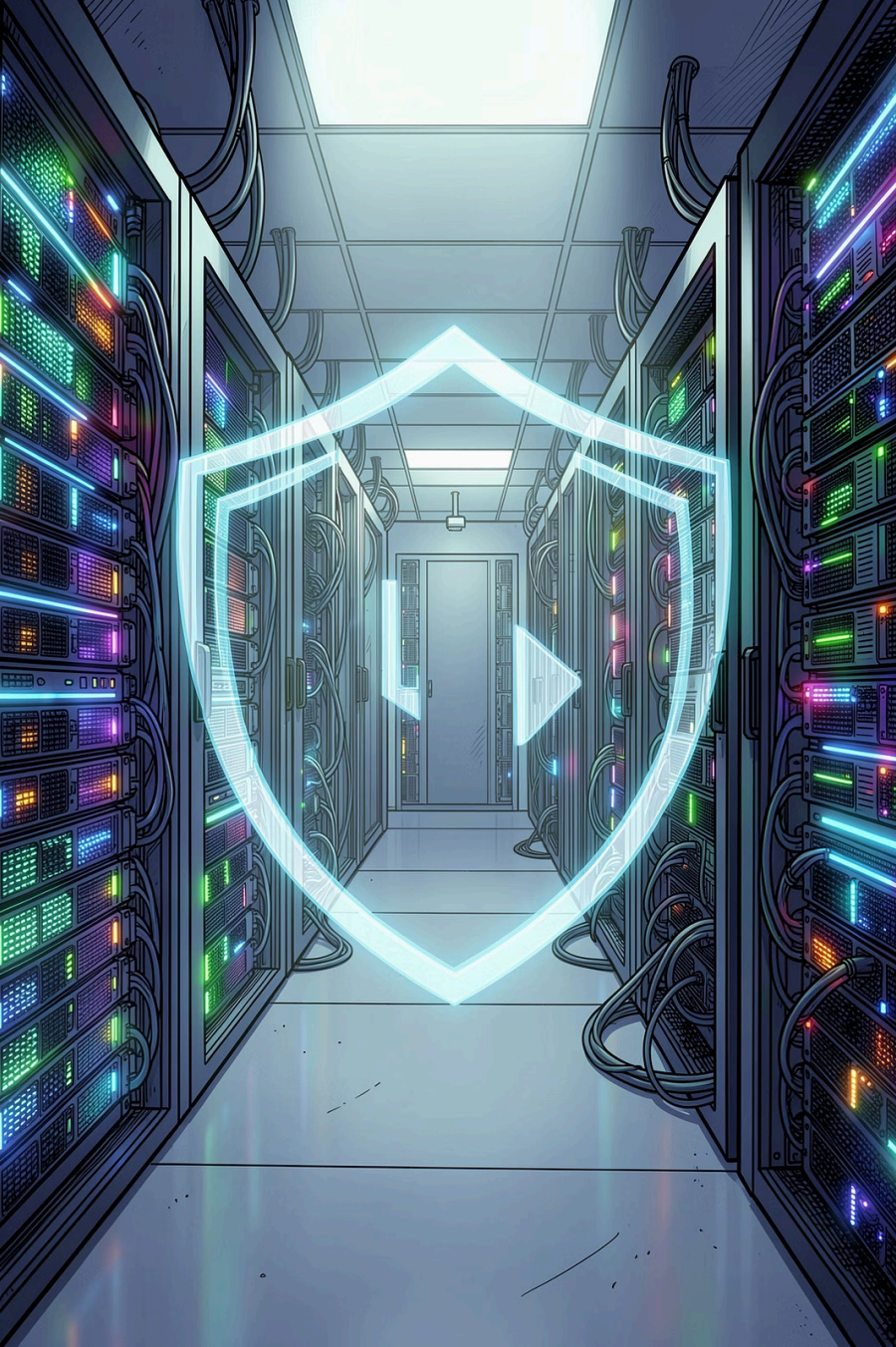
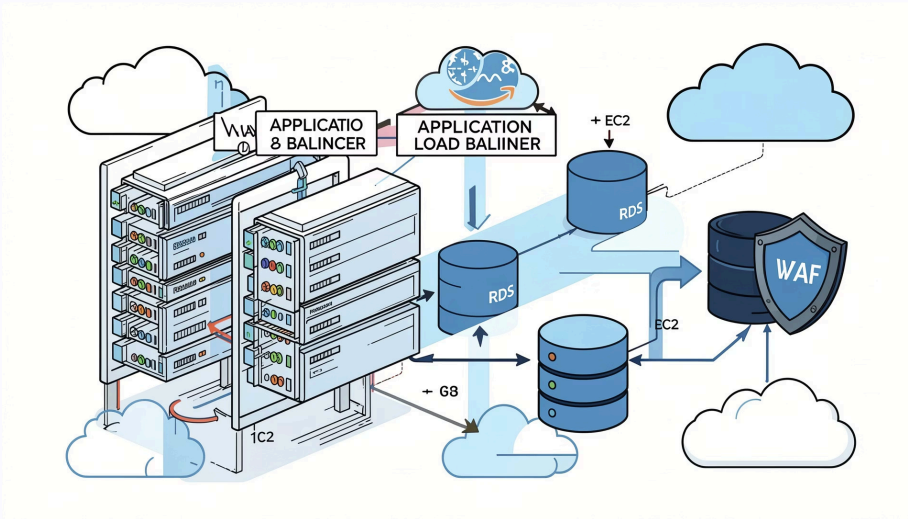




Securing the Front Door: Brute-Force Protection on AWS

Hands-on training demo: an EC2-hosted login/signup app protected by AWS WAF rate-based rules, RDS for accounts, CloudWatch alarms, and SNS alerts — an attackable pattern you can safely demonstrate.

The Architecture: EC2, RDS, and the WAF Shield

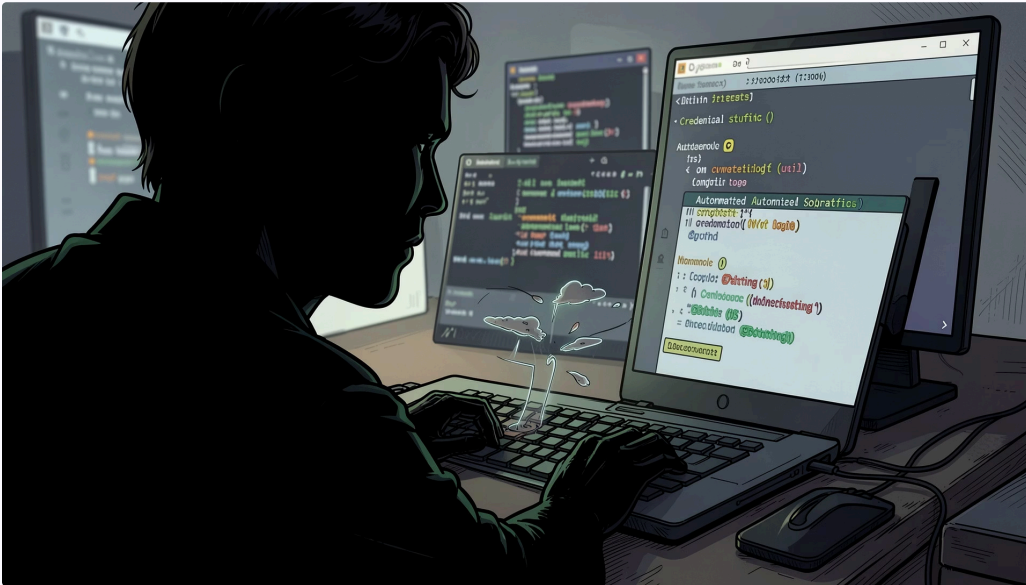


Components

- EC2 instances (web app) behind ALB — serves /login and /signup endpoints
- Amazon RDS (managed) — stores user accounts, hashed passwords, and auth metadata
- AWS WAF at the edge — inspects requests and enforces rate-based rules
- CloudWatch & SNS — observability and alerting pipeline

❏ Design emphasis: place WAF before the origin so malicious traffic is blocked at the network edge.

The Threat: Anatomy of a Brute-Force Attack



Brute-force attacks are automated and opportunistic. Typical behaviors:

- Credential stuffing: large lists of username/password pairs replayed rapidly
- Password spraying: low-volume attempts across many accounts to avoid lockouts
- High request rate targeted at the /login URI to find weak creds or exhaust resources

Risk: account takeover, resource exhaustion, false positives if protection is too broad.

The Defense: WAF Rate-Based Rules

1

Targeted rule

Rate rule scoped to requests where URI path equals `/login` — focuses defense on the attack vector, not the whole site.

2

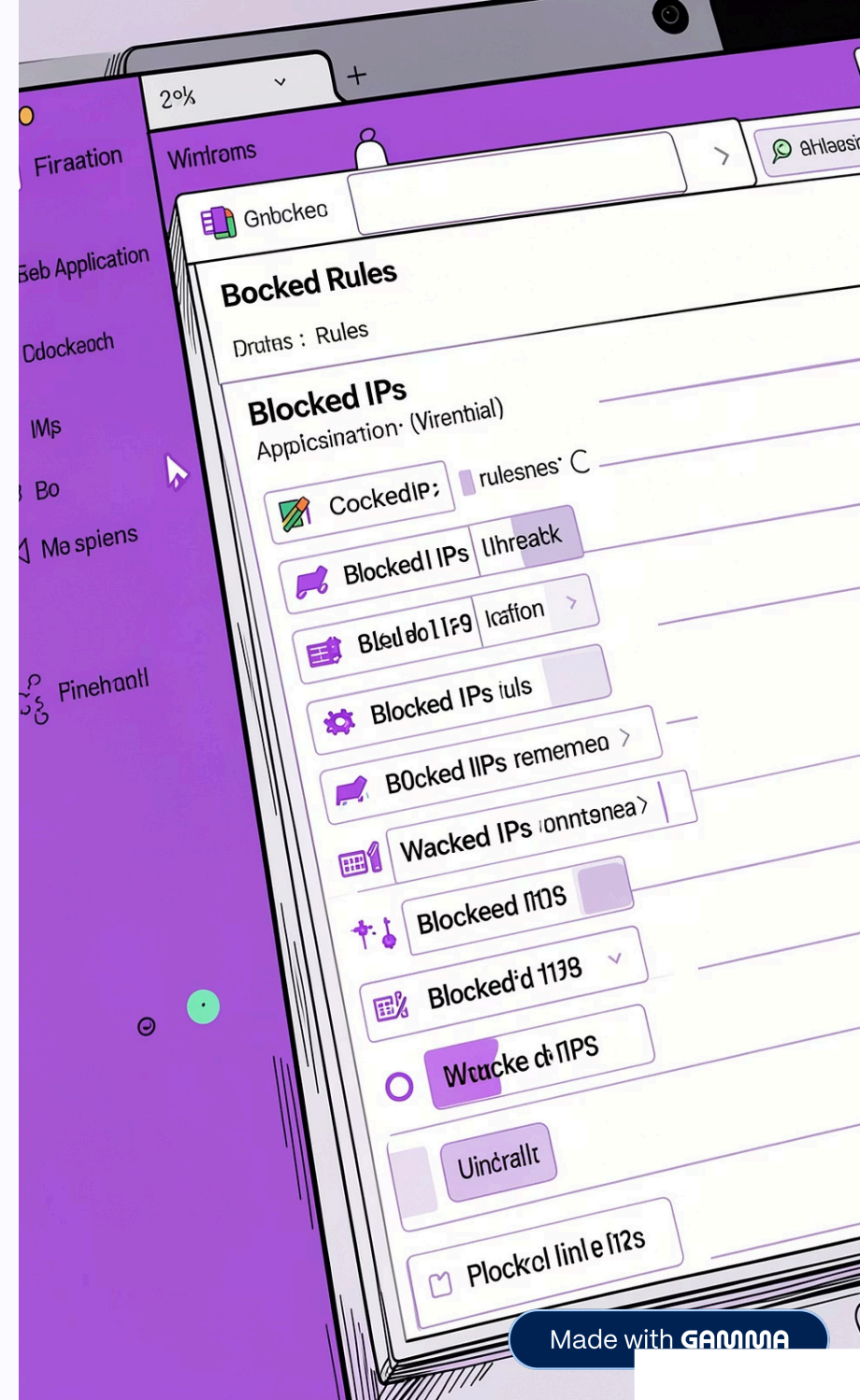
Threshold and window

Set a requests-per-5-minute threshold (tuned for your traffic profile). Exceeding it increments the IP's rate bucket and triggers a block.

3

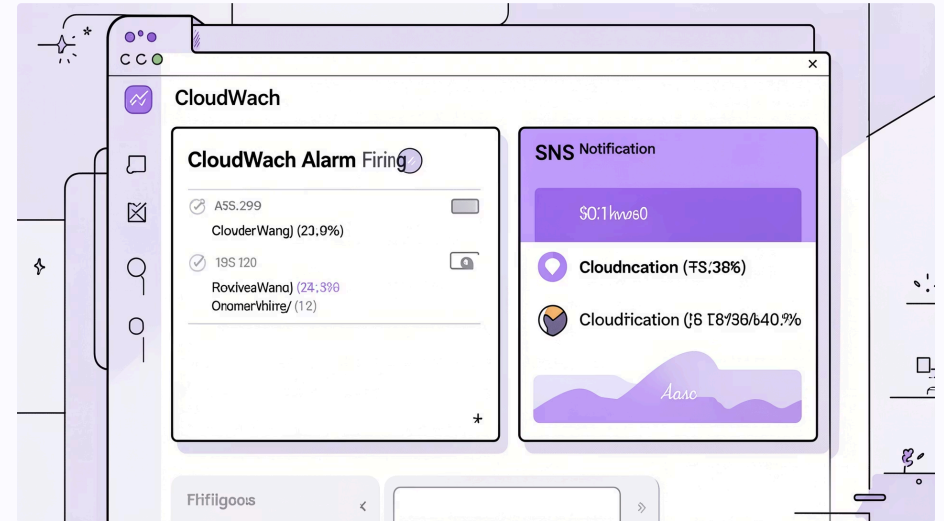
Action: block & count

WAF blocks offending IPs and increments the **BlockedRequests** metric for observability and downstream automation.



Observability: CloudWatch + SNS Automation

Connect WAF outputs to CloudWatch metrics and create an alarm that watches the WAF `BlockedRequests` (filtered to the login rule). When the alarm fires, SNS distributes a notification (email, SMS, or webhook).



01

1. WAF Block

Request exceeds rate limit → WAF blocks IP and emits metric data.

02

2. CloudWatch Alarm

Alarm on aggregated blocked requests or per-rule spikes detects suspicious activity.

03

3. SNS Notification

SNS sends immediate alerts to responders and can trigger automated workflows (blocklists, ticketing).

Live Demo: Attack, Observe, Verify



Step 1 — Simulate the Attack

Run a local script that issues repeated POSTs to /login using benign test accounts — observe request rate and source IP.



Step 3 — Receive SNS Alert

SNS notifies operators with the offending IP and timestamp. Use this to initiate mitigation or forensic capture.



Step 2 — Watch WAF & CloudWatch

CloudWatch metric for WAF rises; alarm triggers when threshold is met.

Demo Tips & Safety

- Run tests from a controlled IP range you own, or inside an isolated lab account.
- Use short, identifiable test payloads so logs are easy to filter.
- Tune thresholds to avoid blocking legitimate traffic — monitor false positives during ramping.

 Pro tip: add temporary CloudWatch dashboards showing blocked IPs + request traces to speed diagnosis.

Key Takeaway

Rate-based WAF rules + CloudWatch + SNS form a practical, demonstrable defense — block attacks at the edge, alert defenders in real time, and preserve origin capacity.